

Daily Vulnerability Report - 2026-09-15

Window (UTC): 2026-09-15T00:00 to 2026-09-16T00:00 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-09-17 10:01:26 UTC

Total	New	Updated	KEV	Critical	High	Medium	Unscored	Watchlist	Packages
1754	1462	292	3	187	937	416	130	122	27

P1 - Act now (KEV / high EPSS)

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-58704 New	8.8	HIGH	Yes	0.001	google:android	In Cellular Modem, there is a possible permission bypass due to a logic error in the code. This could lead to remote (proximal/adjacent) escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-76460 Added to KEV			Yes		cisco:identity services engine	Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) contain an incorrect use of privileged APIs vulnerability that could allow an unauthenticated, remote attacker to gain unauthorized access to the affected device by bypassing the web-based management interface.
CVE-2026-87886 Added to KEV			Yes		acronis:backup	Acronis Backup plugin for cPanel & WHM and extension for Plesk contains an incorrect default permissions vulnerability that could allow for privilege escalation.

P2 - High (CVSS >= 9.0 or 7.0+ with EPSS >= 0.10)

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-53710 New	10.0	CRIT		0.008		MCP Context Forge is an AI gateway, registry, and proxy for MCP, A2A, REST, and gRPC APIs. Prior to 1.0.2, the python_sandbox_server in mcp-servers/python/python_sandbox_server/src/python_sandbox_server/server_fastmcp.py exposes raw getattr through safe_builtins, omits a required _getattr_guard, and relies on validate_code checks for literal dangerous dunder strings. An attacker can construct dunder names at runt...
CVE-2026-59971 New	10.0	CRIT		0.004		MySQL MCP Server is a Model Context Protocol server that enables secure interaction with MySQL databases. Prior to 0.4.2, setting MCP_TRANSPORT=sse causes src/mysql_mcp_server/server.py to construct SseServerTransport without security_settings or enable_dns_rebinding_protection, while the Starlette routes /, /sse, and /messages/ have no authentication and the service binds to 0.0.0.0 by default. A network attacker...
CVE-2026-71133 New	10.0	CRIT		0.003		Vulnerability in the Oracle Access Manager product of Oracle Fusion Middleware (component: Authentication Engine). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.1.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Access Manager. While the vulnerability is in Oracle Access Manager, attacks may significantly impact additional pro...
CVE-2026-83020 New	10.0	CRIT		0.004		Vulnerability in the Oracle Platform Security for Java product of Oracle Fusion Middleware (component: Centralized Thirdparty Jars). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Platform Security for Java. While the vulnerability is in Oracle Platform Security for Java, attac...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-83021 New	10.0	CRIT		0.004		Vulnerability in the Oracle WebLogic Server product of Oracle Fusion Middleware (component: Web Container). Supported versions that are affected are 12.2.1.4.0, 14.1.1.0.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle WebLogic Server. While the vulnerability is in Oracle WebLogic Server, attacks may significantly impact additio...
CVE-2026-83059 New	10.0	CRIT		0.005		Vulnerability in the Oracle Internet Directory product of Oracle Fusion Middleware (component: OID LDAP Server). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.1.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via LDAP to compromise Oracle Internet Directory. While the vulnerability is in Oracle Internet Directory, attacks may significantly impact addition...
CVE-2026-83099 New	10.0	CRIT		0.004		Vulnerability in the Oracle Forms product of Oracle Fusion Middleware (component: Forms Services, C/S, Charmode). Supported versions that are affected are 12.2.1.19.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Forms. While the vulnerability is in Oracle Forms, attacks may significantly impact additional products (scope chang...
CVE-2026-87230 New	10.0	CRIT		0.004		Vulnerability in the Oracle Hyperion Financial Management product of Oracle Hyperion (component: Security). The supported version that is affected is 11.2.26.0.000. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Hyperion Financial Management. While the vulnerability is in Oracle Hyperion Financial Management, attacks may significantly impact ad...
CVE-2026-45579 New	9.9	CRIT		0.004		DIRAC is an interware, meaning a software framework for distributed computing. Prior to versions 8.0.79, 9.0.22, and 9.1.10, the RequestManagementSystem/Service/ReqManagerHandler.py export_getRequestCountersWeb function passes an authenticated caller-controlled groupingAttribute to RequestManagementSystem/DB/RequestDB.py getRequestCountersWeb. An unrecognized value is resolved against the Request object and evalua...
CVE-2026-57138 New	9.9	CRIT		0.004		PraisonAI is a multi-agent teams system. From 1.4.0 until 1.7.2, codeMode in src/praisonai-ts/src/tools/builtins/code-mode.ts executes untrusted JavaScript with new Function() inside with(sandbox) and relies on a small source-code blacklist plus shadowed process and require properties. Code can use ({}).constructor.constructor to recover the real Function constructor, obtain process and process.mainModule.require,...
CVE-2026-61667 New	9.9	CRIT		0.007		DIRAC is an interware, meaning a software framework for distributed computing. Prior to versions 8.0.79, 9.0.22, and 9.1.10, DataManagementSystem/Service/FileCatalogHandler.py checkDataset forwards an authenticated caller-controlled datasets value to DatasetManager.py __checkDataset, where datasetName is interpolated into an FC_MetaDatasets SQL query without parameterization. The injected query can control the ret...
CVE-2026-71163 New	9.9	CRIT		0.003		Vulnerability in the Oracle Access Manager product of Oracle Fusion Middleware (component: Authentication Engine). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.1.0. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Oracle Access Manager. While the vulnerability is in Oracle Access Manager, attacks may significantly impact additional prod...
CVE-2026-73945 New	9.9	CRIT		0.003		Vulnerability in the Oracle Access Manager product of Oracle Fusion Middleware (component: Authentication Engine). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.1.0. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Oracle Access Manager. While the vulnerability is in Oracle Access Manager, attacks may significantly impact additional prod...
CVE-2026-73948 New	9.9	CRIT		0.004		Vulnerability in the Oracle WebCenter Portal product of Oracle Fusion Middleware (component: Composer). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Oracle WebCenter Portal. While the vulnerability is in Oracle WebCenter Portal, attacks may significantly impact additional products (s...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-76669 New	9.9	CRIT		0.004		Privilege escalation vulnerabilities exist in the API of HPE Networking EdgeConnect SD-WAN Orchestrator. Successful exploitation could allow a remote low-privileged authenticated user to escalate their privileges to those of an administrative user, leading to complete system compromise.
CVE-2026-76670 New	9.9	CRIT		0.004		Privilege escalation vulnerabilities exist in the API of HPE Networking EdgeConnect SD-WAN Orchestrator. Successful exploitation could allow a remote low-privileged authenticated user to escalate their privileges to those of an administrative user, leading to complete system compromise.
CVE-2026-76672 New	9.9	CRIT		0.004		A vulnerability exists in the SD-WAN Orchestrator that may lead to the exposure of sensitive configuration information. An authenticated remote attacker with read-only privileges could exploit this vulnerability by sending a specially crafted request to the cache synchronization endpoint. Successful exploitation could result in the disclosure of sensitive third-party API tokens and credentials, potentially enablin...
CVE-2026-82997 New	9.9	CRIT		0.005		Vulnerability in the Service Delivery Platform product of Oracle Fusion Middleware (component: Messaging Enabler). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows low privileged attacker with network access via T3, IIOP to compromise Service Delivery Platform. While the vulnerability is in Service Delivery Platform, attacks may significantly impact add...
CVE-2026-82998 New	9.9	CRIT		0.005		Vulnerability in the Service Delivery Platform product of Oracle Fusion Middleware (component: Messaging Enabler). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows low privileged attacker with network access via T3, IIOP to compromise Service Delivery Platform. While the vulnerability is in Service Delivery Platform, attacks may significantly impact add...
CVE-2026-82999 New	9.9	CRIT		0.005		Vulnerability in the Service Delivery Platform product of Oracle Fusion Middleware (component: Messaging Enabler). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Service Delivery Platform. While the vulnerability is in Service Delivery Platform, attacks may significantly impact additio...
CVE-2026-83031 New	9.9	CRIT		0.005		Vulnerability in the Oracle WebCenter Sites product of Oracle Fusion Middleware (component: WebCenter Sites). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Oracle WebCenter Sites. While the vulnerability is in Oracle WebCenter Sites, attacks may significantly impact additional product...
CVE-2026-83038 New	9.9	CRIT		0.003		Vulnerability in the Oracle WebLogic Server product of Oracle Fusion Middleware (component: TopLink Integration). Supported versions that are affected are 12.2.1.4.0, 14.1.1.0.0, 14.1.2.0.0 and 15.1.1.0.0. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Oracle WebLogic Server. While the vulnerability is in Oracle WebLogic Server, attacks may significant...
CVE-2026-83039 New	9.9	CRIT		0.005		Vulnerability in the Oracle WebCenter Portal product of Oracle Fusion Middleware (component: Composer). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Oracle WebCenter Portal. While the vulnerability is in Oracle WebCenter Portal, attacks may significantly impact additional products (s...
CVE-2026-83055 New	9.9	CRIT		0.004		Vulnerability in the Oracle Internet Directory product of Oracle Fusion Middleware (component: OID LDAP Server). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.1.0. Easily exploitable vulnerability allows low privileged attacker with network access via LDAP to compromise Oracle Internet Directory. While the vulnerability is in Oracle Internet Directory, attacks may significantly impact additiona...
CVE-2026-83056 New	9.9	CRIT		0.005		Vulnerability in the Oracle Internet Directory product of Oracle Fusion Middleware (component: OID LDAP Server). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.1.0. Easily exploitable vulnerability allows low privileged attacker with network access via LDAP to compromise Oracle Internet Directory. While the vulnerability is in Oracle Internet Directory, attacks may significantly impact additiona...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-83057 New	9.9	CRIT		0.005		Vulnerability in the Oracle Internet Directory product of Oracle Fusion Middleware (component: OID LDAP Server). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.1.0. Easily exploitable vulnerability allows low privileged attacker with network access via LDAP to compromise Oracle Internet Directory. While the vulnerability is in Oracle Internet Directory, attacks may significantly impact additiona...
CVE-2026-83058 New	9.9	CRIT		0.004		Vulnerability in the Oracle Internet Directory product of Oracle Fusion Middleware (component: OID LDAP Server). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.1.0. Easily exploitable vulnerability allows low privileged attacker with network access via LDAP to compromise Oracle Internet Directory. While the vulnerability is in Oracle Internet Directory, attacks may significantly impact additiona...
CVE-2026-83282 New	9.9	CRIT		0.003		Vulnerability in the Oracle Business Intelligence Enterprise Edition product of Oracle Analytics (component: Platform Security). The supported version that is affected is 12.2.1.4.0. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Oracle Business Intelligence Enterprise Edition. While the vulnerability is in Oracle Business Intelligence Enterprise Editi...
CVE-2026-87172 New	9.9	CRIT		0.004		Vulnerability in the Oracle Hyperion Financial Management product of Oracle Hyperion (component: Security). The supported version that is affected is 11.2.26.0.000. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Oracle Hyperion Financial Management. While the vulnerability is in Oracle Hyperion Financial Management, attacks may significantly impact add...
CVE-2026-91998 New	9.9	CRIT		0.004		Casdoor through 4.4.0 contains an authorization bypass vulnerability in the /api/mcp endpoint that allows attackers with any application's clientId and clientSecret to gain unrestricted access to user administration across all organizations. Attackers can enumerate user records including password salts and email addresses, create administrator accounts, modify existing users, and delete them in any organization by...
CVE-2024-58385 New	9.8	CRIT		0.004		Yonyou U8 CRM contains an unauthenticated SQL injection vulnerability in the fillbacksettingedit.php configuration endpoint where the DontCheckLogin=1 parameter bypasses authentication and the id parameter is incorporated into SQL queries without sanitization. Attackers can exploit this flaw to execute arbitrary SQL commands and, on Microsoft SQL Server deployments with xp_cmdshell enabled, write backdoor files an...
CVE-2026-12351 New	9.8	CRIT		0.009		IBM MQ 9.3.0.0 through 9.3.0.41 LTS, 9.3.0.0 through 9.3.5.1 CD, 9.4.0.0 through 9.4.0.25 LTS, 9.4.0.0 through 9.4.5.1 LTS, and 10.0.0.0 could allow a remote attacker to execute arbitrary code due to unsafe JNDI lookup processing when the IVT application is deployed.
CVE-2026-19773 New	9.8	CRIT		0.006		libwebsockets HTTP/2 HPACK Path Header Parsing Out-Of-Bounds Write Remote Code Execution Vulnerability. This vulnerability allows remote attackers to execute arbitrary code on affected installations of libwebsockets. Authentication is not required to exploit this vulnerability. The specific flaw exists within the parsing of HTTP/2 HPACK path header. The issue results from the lack of proper validation of user-sup...
CVE-2026-19931 Newly scored	9.8	CRIT		0.012	haxx:curl	A flaw in libcurl makes it wrongly reuse an HTTP connection setup for a given hostname using Negotiate authentication, when the initial request is done using empty credentials. This can make user B's request get sent over user A's previously authenticated connection.
CVE-2026-20274 Newly scored	9.8	CRIT		0.007		As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco IOS XR Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20274 are related to improper resource control issues that are grouped under th...
CVE-2026-20279 Newly scored	9.8	CRIT		0.003		As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco IOS XR Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20279 are related to improper access control issues that are grouped under the ...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-28606 Newly scored	9.8	CRIT		0.003	google:android	In handleBondStateChanged of AdapterService.java, there is a possible way to skip pairing due to a logic error in the code. This could lead to remote escalation of privilege without user consent with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-37152 New	9.8	CRIT		0.002		TOTOLINK X5000R V9.1.0cu.2415_B20250515 was discovered to contain a hardcoded password for root access.
CVE-2026-39919 New	9.8	CRIT		0.005		Ghostsript before 10.08.0 contains a heap-based buffer overflow vulnerability in the JPEG 2000 output adapter (base/sjpx_openjpeg.c) that allows attackers to cause memory corruption by supplying a crafted PDF containing a JPEG 2000 image with mismatched component subsampling factors. When image components declare different subsampling values, the non-samescale sub-byte-depth output path allocates a row buffer siz...
CVE-2026-52098 Newly scored	9.8	CRIT		0.008	flowiseai:flowise	An issue in Flowise 3.1.2 allows a remote attacker to execute arbitrary code via the /api/v1/prediction/<flowId> endpoint
CVE-2026-54337 New	9.8	CRIT		0.004		Fireshare facilitates self-hosted media and link sharing. Prior to version 1.6.14, an argument Injection in the video upload function allows unauthenticated attacker to write/overwrite system files. Version 1.6.14 fixes the issue.
CVE-2026-55211 New	9.8	CRIT		0.005		Surfio is a library for reading and writing surface files. Prior to 0.0.19, surfio does not correctly validate size fields in IRAP files, leading to a buffer overflow when untrusted files are parsed. The severity assumes surfio is used to parse untrusted files in a networking context such as a web service. This issue is fixed in version 0.0.19.
CVE-2026-55366 New	9.8	CRIT		0.002		In IP Multimedia Subsystem, there is a possible authentication bypass due to a logic error in the code. This could lead to remote escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-56960 New	9.8	CRIT		0.002		In multiple locations, there is a possible use-after-free due to a logic error in the code. This could lead to remote escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
CVE-2026-57139 New	9.8	CRIT		0.004		PraisonAI is a multi-agent teams system. From 1.5.0 until 1.7.2, MCPServer.startHttp() in src/praisonai-ts/src/mcp/server.ts binds without a host restriction and forwards every HTTP POST request to handleRequest() without authentication or authorization. Any network client that can reach the port can call tools/list, tools/call, resources/read, or prompts/get, causing registered handlers to run with server-side cr...
CVE-2026-57141 New	9.8	CRIT		0.005		PraisonAI is a multi-agent teams system. Prior to 1.7.2, the codeMode tool in src/praisonai-ts/src/tools/builtins/code-mode.ts executes model-generated JavaScript with new Function() and with(sandbox), while a regular-expression blacklist can be bypassed with Function('return this')() to recover the global object and by constructing the child_process module name dynamically. An attacker who can influence the code ...
CVE-2026-57147 New	9.8	CRIT		0.008		PraisonAI is a multi-agent teams system. Prior to 0.1.6, praisonai_platform/services/auth_service.py assigns the public dev-secret-change-me value to JWT_SECRET when PLATFORM_JWT_SECRET is unset, and its production guard does not run when PLATFORM_ENV is also unset because that setting defaults to dev. A remote unauthenticated attacker can mint an HS256 token with an arbitrary sub and email, and the platform's Aut...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-57148 New	9.8	CRIT		0.004		PraisonAI is a multi-agent teams system. Prior to 0.1.6, praisonai_platform/services/auth_service.py falls back to the public dev-secret-change-me HS256 signing key when PLATFORM_JWT_SECRET is unset, while the startup and token-issuance guards are disabled because PLATFORM_ENV also defaults to dev. An unauthenticated attacker can sign a JWT containing an attacker-chosen sub value, and AuthService._verify_token() a...
CVE-2026-61560 New	9.8	CRIT		0.007		`@zereight/mcp-gitlab` is a Model Context Protocol server for GitLab. Prior to version 2.1.27, the SSE transport mode (`SSE=true`) exposes all MCP tools without any authentication. The `upload_markdown` tool reads arbitrary files from the server's local filesystem via an unsanitized `file_path` parameter and uploads them to a GitLab project. Combined, any unauthenticated network-reachable attacker can read `/proc/...
CVE-2026-62379 New	9.8	CRIT		0.006		Open Access Management (OpenAM) is an access management solution. Prior to 16.1.2, the pre-authentication /authservice PLL endpoint accepts a CustomCallback XML element whose className value selects an arbitrary Java class for AuthXMLUtils to load and instantiate without verifying that it implements DSAMECallbackInterface. Default configurations expose the endpoint without authentication, allowing attacker-control...
CVE-2026-63695 New	9.8	CRIT		0.005		Dell SmartFabric OS10 Software, versions prior to 10.6.1.3, contains a Session Fixation vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to Session theft.
CVE-2026-70748 New	9.8	CRIT		0.003		Vulnerability in the Oracle WebLogic Server product of Oracle Fusion Middleware (component: Core). Supported versions that are affected are 12.2.1.4.0, 14.1.1.0.0, 14.1.2.0.0 and 15.1.1.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via T3, IIOP to compromise Oracle WebLogic Server. Successful attacks of this vulnerability can result in takeover of Oracle WebLogic Serv...
CVE-2026-70756 New	9.8	CRIT		0.004		Vulnerability in the Oracle WebLogic Server product of Oracle Fusion Middleware (component: Core). Supported versions that are affected are 12.2.1.4.0, 14.1.1.0.0, 14.1.2.0.0 and 15.1.1.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via T3, IIOP to compromise Oracle WebLogic Server. Successful attacks of this vulnerability can result in takeover of Oracle WebLogic Serv...
CVE-2026-70757 New	9.8	CRIT		0.003		Vulnerability in the Oracle WebLogic Server product of Oracle Fusion Middleware (component: Core). Supported versions that are affected are 12.2.1.4.0, 14.1.1.0.0, 14.1.2.0.0 and 15.1.1.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via T3, IIOP to compromise Oracle WebLogic Server. Successful attacks of this vulnerability can result in takeover of Oracle WebLogic Serv...
CVE-2026-70913 New	9.8	CRIT		0.003		Vulnerability in the Oracle Identity Manager product of Oracle Fusion Middleware (component: Core). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.1.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Identity Manager. Successful attacks of this vulnerability can result in takeover of Oracle Identity Manager. CVSS 3.1 Base Score 9...
CVE-2026-73940 New	9.8	CRIT		0.004		Vulnerability in the Oracle Access Manager product of Oracle Fusion Middleware (component: Authentication Engine). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.1.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via T3, IIOP to compromise Oracle Access Manager. Successful attacks of this vulnerability can result in takeover of Oracle Access Manager. CVSS 3...
CVE-2026-73947 New	9.8	CRIT		0.003		Vulnerability in the Oracle Access Manager product of Oracle Fusion Middleware (component: Authentication Engine). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Access Manager. Successful attacks of this vulnerability can result in takeover of Oracle Access Manager. CVSS 3.1 B...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-73950 New	9.8	CRIT		0.004		Vulnerability in the Oracle Access Manager product of Oracle Fusion Middleware (component: Authentication Engine). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.1.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Access Manager. Successful attacks of this vulnerability can result in takeover of Oracle Access Manager. CVSS 3.1 B...
CVE-2026-73953 New	9.8	CRIT		0.004		Vulnerability in the Oracle WebCenter Portal product of Oracle Fusion Middleware (component: Portlet Services). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle WebCenter Portal. Successful attacks of this vulnerability can result in takeover of Oracle WebCenter Portal. CVSS 3.1 ...
CVE-2026-73956 New	9.8	CRIT		0.005		Vulnerability in the Oracle WebCenter Portal product of Oracle Fusion Middleware (component: Composer). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle WebCenter Portal. Successful attacks of this vulnerability can result in takeover of Oracle WebCenter Portal. CVSS 3.1 Base Sco...
CVE-2026-73961 New	9.8	CRIT		0.005		Vulnerability in the Oracle JDeveloper product of Oracle Fusion Middleware (component: ADF Faces). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle JDeveloper. Successful attacks of this vulnerability can result in takeover of Oracle JDeveloper. CVSS 3.1 Base Score 9.8 (Confident...
CVE-2026-73963 New	9.8	CRIT		0.004		Vulnerability in the Oracle WebCenter Portal product of Oracle Fusion Middleware (component: Portlet Services). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle WebCenter Portal. Successful attacks of this vulnerability can result in takeover of Oracle WebCenter Portal. CVSS 3.1 ...
CVE-2026-76673 New	9.8	CRIT		0.005		Vulnerabilities have been identified in the API of EdgeConnect SD-WAN Orchestrator that could potentially allow an unauthenticated remote actor to circumvent existing authentication controls. Successful exploitation could allow an attacker to gain administrative privileges leading to complete compromise of the EdgeConnect SD-WAN Orchestrator host.
CVE-2026-76674 New	9.8	CRIT		0.011		Buffer overflow vulnerabilities exist in the underlying operating system of HPE Networking EdgeConnect SD-WAN Gateways that could allow an unauthenticated remote attacker to execute arbitrary code. Successful exploitation could allow an attacker to execute arbitrary commands on the underlying operating system leading to complete system compromise.
CVE-2026-82994 New	9.8	CRIT		0.005		Vulnerability in the Oracle Platform Security for Java product of Oracle Fusion Middleware (component: Centralized Thirdparty Jars). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via LDAP to compromise Oracle Platform Security for Java. Successful attacks of this vulnerability can result in takeover of Ora...
CVE-2026-82995 New	9.8	CRIT		0.005		Vulnerability in the Oracle Platform Security for Java product of Oracle Fusion Middleware (component: Centralized Thirdparty Jars). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via SOAP to compromise Oracle Platform Security for Java. Successful attacks of this vulnerability can result in takeover of Ora...
CVE-2026-83000 New	9.8	CRIT		0.005		Vulnerability in the Service Delivery Platform product of Oracle Fusion Middleware (component: Messaging Enabler). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Service Delivery Platform. Successful attacks of this vulnerability can result in takeover of Service Delivery Platform. CV...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-83035 New	9.8	CRIT		0.005		Vulnerability in the Oracle WebCenter Sites product of Oracle Fusion Middleware (component: WebCenter Sites). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle WebCenter Sites. Successful attacks of this vulnerability can result in takeover of Oracle WebCenter Sites. CVSS 3.1 Base...
CVE-2026-83036 New	9.8	CRIT		0.005		Vulnerability in the Oracle WebCenter Sites product of Oracle Fusion Middleware (component: WebCenter Sites). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle WebCenter Sites. Successful attacks of this vulnerability can result in takeover of Oracle WebCenter Sites. CVSS 3.1 Base...
CVE-2026-83037 New	9.8	CRIT		0.005		Vulnerability in the Oracle WebCenter Sites product of Oracle Fusion Middleware (component: WebCenter Sites). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle WebCenter Sites. Successful attacks of this vulnerability can result in takeover of Oracle WebCenter Sites. CVSS 3.1 Base...
CVE-2026-83042 New	9.8	CRIT		0.005		Vulnerability in the Oracle Identity Manager product of Oracle Fusion Middleware (component: OIM Legacy UI). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.1.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Identity Manager. Successful attacks of this vulnerability can result in takeover of Oracle Identity Manager. CVSS 3.1 Bas...
CVE-2026-83054 New	9.8	CRIT		0.004		Vulnerability in the Oracle Internet Directory product of Oracle Fusion Middleware (component: OID LDAP Server). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.1.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via LDAP to compromise Oracle Internet Directory. Successful attacks of this vulnerability can result in takeover of Oracle Internet Directory. CVSS...
CVE-2026-83060 New	9.8	CRIT		0.005		Vulnerability in the Oracle Internet Directory product of Oracle Fusion Middleware (component: OID LDAP Server). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.1.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via LDAP to compromise Oracle Internet Directory. Successful attacks of this vulnerability can result in takeover of Oracle Internet Directory. CVSS...
CVE-2026-83061 New	9.8	CRIT		0.005		Vulnerability in the Oracle Internet Directory product of Oracle Fusion Middleware (component: OID LDAP Server). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.1.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via LDAP to compromise Oracle Internet Directory. Successful attacks of this vulnerability can result in takeover of Oracle Internet Directory. CVSS...
CVE-2026-83062 New	9.8	CRIT		0.005		Vulnerability in the Oracle Internet Directory product of Oracle Fusion Middleware (component: OID LDAP Server). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.1.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via LDAP to compromise Oracle Internet Directory. Successful attacks of this vulnerability can result in takeover of Oracle Internet Directory. CVSS...
CVE-2026-83066 New	9.8	CRIT		0.005		Vulnerability in the Oracle Internet Directory product of Oracle Fusion Middleware (component: OID LDAP Server). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.1.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via T3, IIOP to compromise Oracle Internet Directory. Successful attacks of this vulnerability can result in takeover of Oracle Internet Directory. ...
CVE-2026-83094 New	9.8	CRIT		0.005		Vulnerability in the Oracle Forms product of Oracle Fusion Middleware (component: Forms Services, C/S, Charmode). Supported versions that are affected are 12.2.1.19.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Forms. Successful attacks of this vulnerability can result in takeover of Oracle Forms. CVSS 3.1 Base Score 9.8 (Con...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-83095 New	9.8	CRIT		0.005		Vulnerability in the Oracle Forms product of Oracle Fusion Middleware (component: Forms Services, C/S, Charmode). Supported versions that are affected are 12.2.1.19.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Forms. Successful attacks of this vulnerability can result in takeover of Oracle Forms. CVSS 3.1 Base Score 9.8 (Con...
CVE-2026-83098 New	9.8	CRIT		0.004		Vulnerability in the Oracle Forms product of Oracle Fusion Middleware (component: Forms Services, C/S, Charmode). Supported versions that are affected are 12.2.1.19.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Forms. Successful attacks of this vulnerability can result in takeover of Oracle Forms. CVSS 3.1 Base Score 9.8 (Con...
CVE-2026-83100 New	9.8	CRIT		0.005		Vulnerability in the Oracle Forms product of Oracle Fusion Middleware (component: Forms Services, C/S, Charmode). Supported versions that are affected are 12.2.1.19.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Forms. Successful attacks of this vulnerability can result in takeover of Oracle Forms. CVSS 3.1 Base Score 9.8 (Con...
CVE-2026-83108 New	9.8	CRIT		0.004		Vulnerability in the Oracle Forms product of Oracle Fusion Middleware (component: Forms Services, C/S, Charmode). Supported versions that are affected are 12.2.1.19.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Forms. Successful attacks of this vulnerability can result in takeover of Oracle Forms. CVSS 3.1 Base Score 9.8 (Con...
CVE-2026-83151 New	9.8	CRIT		0.004		Vulnerability in the Service Delivery Platform product of Oracle Fusion Middleware (component: Messaging Enabler). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via SOAP to compromise Service Delivery Platform. Successful attacks of this vulnerability can result in takeover of Service Delivery Platform. CV...
CVE-2026-83232 New	9.8	CRIT		0.003		Vulnerability in the Oracle Data Integrator product of Oracle Fusion Middleware (component: Console / Repository Explorer). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Data Integrator. Successful attacks of this vulnerability can result in takeover of Oracle Data Integrator....
CVE-2026-83261 New	9.8	CRIT		0.004		Vulnerability in the Oracle Product Lifecycle Analytics product of Oracle Supply Chain (component: Core). The supported version that is affected is 3.6.1. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Product Lifecycle Analytics. Successful attacks of this vulnerability can result in takeover of Oracle Product Lifecycle Analytics. CVSS 3.1 Bas...
CVE-2026-83269 New	9.8	CRIT		0.004		Vulnerability in the Oracle BI Publisher product of Oracle Analytics (component: BI Platform Security). Supported versions that are affected are 8.2.0.0.0, 12.2.1.4.0 and 26.01.0.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle BI Publisher. Successful attacks of this vulnerability can result in takeover of Oracle BI Publisher. CVSS 3.1 Base...
CVE-2026-83283 New	9.8	CRIT		0.004		Vulnerability in the Oracle Business Intelligence Enterprise Edition product of Oracle Analytics (component: Platform Security). The supported version that is affected is 12.2.1.4.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Business Intelligence Enterprise Edition. Successful attacks of this vulnerability can result in takeover of Oracle ...
CVE-2026-83327 New	9.8	CRIT		0.005		Vulnerability in the Oracle Applications Framework product of Oracle E-Business Suite (component: Personalization). Supported versions that are affected are 12.2.3-12.2.15. Easily exploitable vulnerability allows unauthenticated attacker with network access via SOAP to compromise Oracle Applications Framework. Successful attacks of this vulnerability can result in takeover of Oracle Applications Framework. CVSS ...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-83339 New	9.8	CRIT		0.005		Vulnerability in the Oracle WebCenter Enterprise Capture product of Oracle Fusion Middleware (component: Client Bundle). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle WebCenter Enterprise Capture. Successful attacks of this vulnerability can result in takeover of Oracle WebCen...
CVE-2026-83355 New	9.8	CRIT		0.004		Vulnerability in the Oracle Enterprise Manager for Fusion Middleware product of Oracle Enterprise Manager (component: Metrics). Supported versions that are affected are 13.5 and 24.1. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Enterprise Manager for Fusion Middleware. Successful attacks of this vulnerability can result in takeover of Oracle...
CVE-2026-83452 New	9.8	CRIT		0.005		Vulnerability in the Oracle Document Management and Collaboration product of Oracle E-Business Suite (component: Internal Operations). Supported versions that are affected are 12.2.3-12.2.15. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Document Management and Collaboration. Successful attacks of this vulnerability can result in takeover of Or...
CVE-2026-83462 New	9.8	CRIT		0.005		Vulnerability in the Oracle Mobile Application Server product of Oracle E-Business Suite (component: MWA Terminal Server). Supported versions that are affected are 12.2.3-12.2.15. Easily exploitable vulnerability allows unauthenticated attacker with network access via TCP to compromise Oracle Mobile Application Server. Successful attacks of this vulnerability can result in takeover of Oracle Mobile Application S...
CVE-2026-85025 Newly scored	9.8	CRIT		0.004	langflow:langflow	IBM Langflow OSS 1.0.0 through 1.11.5 Langflow could allow an unauthenticated attacker to execute arbitrary code and access or modify chat sessions through publicly shared MCP project endpoints due to improper enforcement of public-flow security restrictions and session isolation controls.
CVE-2026-87184 New	9.8	CRIT		0.005		Vulnerability in the Oracle Hyperion Financial Management product of Oracle Hyperion (component: Security). The supported version that is affected is 11.2.26.0.000. Easily exploitable vulnerability allows unauthenticated attacker with network access via SQL to compromise Oracle Hyperion Financial Management. Successful attacks of this vulnerability can result in takeover of Oracle Hyperion Financial Management....
CVE-2026-87188 New	9.8	CRIT		0.004		Vulnerability in the Oracle Hyperion Financial Management product of Oracle Hyperion (component: Security). The supported version that is affected is 11.2.26.0.000. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Hyperion Financial Management. Successful attacks of this vulnerability can result in takeover of Oracle Hyperion Financial Management...
CVE-2026-88617 New	9.8	CRIT		0.002		SmartAdmin v3.30.0 contains an authorization flaw in the configuration query endpoint. This allows a remote attacker to escalate privileges.
CVE-2026-89026 New	9.8	CRIT		0.005		The Issabel Framework, the web framework supporting Issabel PBX software, before commit b97dbaf contains a hard-coded HS256 JWT signing key in the pbxapi index.php file that is identical across every installation, allowing unauthenticated remote attackers to forge valid bearer tokens. Attackers can use the forged token to call the manager originate endpoint with the System application parameter, causing Asterisk t...
CVE-2026-61559 New	9.6	CRIT		0.003	npm:@zereight/mcp-gitlab fixed: 2.1.27	`@zereight/mcp-gitlab` is a Model Context Protocol server for GitLab. Starting in version 0.0.1 and prior to version 2.1.27, when the environment variable `ENABLE_DYNAMIC_API_URL=true` is set, the server reads the `X-GitLab-API-URL` HTTP request header and uses it as the base URL for all outbound GitLab API calls made within that request. The server validates that the value is a well-formed URL (`new URL(dynamicAp...
CVE-2026-61568 New	9.6	CRIT		0.003	npm:@zereight/mcp-gitlab fixed: 2.1.30	`@zereight/mcp-gitlab` is a Model Context Protocol server for GitLab. Versions prior to 2.1.30 expose the Streamable HTTP MCP endpoint without an effective Host or Origin allowlist. A malicious web page can use DNS rebinding to route browser requests to a victim's local MCP listener while preserving an attacker-controlled `Host` and `Origin`. The server accepts those headers and reaches the MCP initialization path...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-73962 New	9.6	CRIT		0.003		Vulnerability in the Oracle Access Manager product of Oracle Fusion Middleware (component: Authentication Engine). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.1.0. Easily exploitable vulnerability allows low privileged attacker with network access via HTTPS to compromise Oracle Access Manager. While the vulnerability is in Oracle Access Manager, attacks may significantly impact additional pro...
CVE-2026-77822 Newly scored	9.6	CRIT		0.002	ibm:contextforge	IBM ContextForge MCP Gateway could allow a remote authenticated attacker to obtain sensitive information due to server-side request forgery via DNS rebinding.
CVE-2026-83029 New	9.6	CRIT		0.004		Vulnerability in the Oracle Managed File Transfer product of Oracle Fusion Middleware (component: MFT Runtime Server). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows low privileged attacker with network access via HTTP to compromise Oracle Managed File Transfer. While the vulnerability is in Oracle Managed File Transfer, attacks may significantly impa...
CVE-2026-83040 New	9.6	CRIT		0.004		Vulnerability in the Oracle WebCenter Portal product of Oracle Fusion Middleware (component: Portlet Services). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via SOAP to compromise Oracle WebCenter Portal. Successful attacks require human interaction from a person other than the attacker and while the vuln...
CVE-2026-83043 New	9.6	CRIT		0.004		Vulnerability in the Oracle WebCenter Portal product of Oracle Fusion Middleware (component: Composer). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle WebCenter Portal. Successful attacks require human interaction from a person other than the attacker and while the vulnerabilit...
CVE-2026-87186 New	9.6	CRIT		0.002		Vulnerability in the Oracle Hyperion Financial Management product of Oracle Hyperion (component: Security). The supported version that is affected is 11.2.26.0.000. Easily exploitable vulnerability allows unauthenticated attacker with access to the physical communication segment attached to the hardware where the Oracle Hyperion Financial Management executes to compromise Oracle Hyperion Financial Management. W...
CVE-2026-91710 New	9.6	CRIT		0.002		Use after free in WebAppInstalls in Google Chrome prior to 153.0.8010.47 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-91716 New	9.6	CRIT		0.002		Use after free in Auth in Google Chrome prior to 153.0.8010.47 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-91718 New	9.6	CRIT		0.002		Use after free in Core in Google Chrome prior to 153.0.8010.47 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-91728 New	9.6	CRIT		0.004		Integer overflow in V8 in Google Chrome prior to 153.0.8010.47 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-91729 New	9.6	CRIT		0.002		Use after free in DigitalCredentials in Google Chrome prior to 153.0.8010.47 allowed a remote attacker leveraging social engineering to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-91738 New	9.6	CRIT		0.002		Improper input validation in ANGLE in Google Chrome prior to 153.0.8010.47 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-91749 New	9.6	CRIT		0.003		Use after free in Workers in Google Chrome prior to 153.0.8010.47 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-78225 New	9.5	CRIT		0.004		A hardcoded cryptographic server key vulnerability exists in the deployer-ng Update Controller component of Wärsilä FOS-Onboard.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-57140 New	9.4	CRIT		0.004		PraisonAI is a multi-agent teams system. From 1.6.0 until 1.7.2, AgentOS in src/praisonai-ts/src/os/agentos.ts uses the 0.0.0.0 default from src/praisonai-ts/src/os/config.ts and registers GET /api/agents and POST /api/chat without authentication middleware. A remote caller who can reach the service can obtain agent names, roles, and instruction prefixes and can invoke a selected agent, potentially reaching its to...
CVE-2026-66887 New	9.4	CRIT		0.002		The affected products are missing authorization on state-changing CGIs and session checks are not performed.
CVE-2026-66890 New	9.4	CRIT		0.002		The affected products use hard-coded credentials, which could allow remote access to files with root privileges where FTP is reachable.
CVE-2026-68491 New	9.4	CRIT		0.003		An insufficient check allowed for the overwrite of arbitrary files via a symlink.
CVE-2026-77179 New	9.4	CRIT		0.002		On macOS, the virtio-fs host server used by Docker Sandboxes improperly follows symlinks when reopening an unlinked file from a stored path. A malicious guest can replace a parent directory with a symlink, escape the shared workspace, and read or modify arbitrary host files as the VMM user, potentially achieving host code execution.
CVE-2023-54398 New	9.3	CRIT		0.006		Yonyou U8 Cloud contains an unauthenticated Java deserialization vulnerability in the nc.impl.pub.filesystem.FileManageServlet component that allows remote unauthenticated attackers to execute arbitrary OS commands by sending a serialized payload via POST request. Attackers can exploit the doAction method, which passes raw HTTP request body data directly to ObjectInputStream.readObject() without filtering, to achi...
CVE-2026-45052 New	9.3	CRIT		0.003		Open Access Management (OpenAM) is an access management solution. Prior to 16.1.1, the Liberty Web Services SOAP receiver permits unauthenticated remote requests to write persistent entries through SOAPReceiver and DiscoveryService into a user's Liberty Discovery store and the shared root-realm Discovery branch. The server-side handlers bypass requester LDAP and identity ACLs, and the global path uses an internal ...
CVE-2026-46619 New	9.3	CRIT		0.006		Open Access Management (OpenAM) is an access management solution. Prior to 16.1.1, MSISDNValidation in the MSISDN authentication module concatenates the request-supplied MSISDN value into an LDAP search filter without escaping, while the default empty trusted-gateway list allows all traffic. In a realm where an MSISDN module is enabled in a reachable authentication chain, an unauthenticated remote attacker can inj...
CVE-2026-53459 New	9.3	CRIT		0.004		Bambuddy is a self-hosted print archive and management system for Bambu Lab 3D printers. Starting in version 0.1.6 and prior to version 0.2.4.4, a fail-open in the authentication code allows any attacker to bypass authentication by flooding a public endpoint to exhaust resources causing database access to fail, granting unauthenticated access to all protected endpoints. Version 0.2.4.4 patches the issue.
CVE-2026-54072 Newly scored	9.3	CRIT		0.003		Authorizer is an open-source, self-hostable authentication and authorization server. Prior to version 2.2.1, the `authorize` endpoint accepts any `redirect_uri` without validating it against `AllowedOrigins`. When `response_type=token` or `response_type=id_token`, the server appends `access_token`, `id_token`, and `refresh_token` as query parameters and issues a 302 redirect to the attacker-supplied URL. An unaut...
CVE-2026-72709 Newly scored	9.3	CRIT		0.004		SPIP before version 4.4.18 contains a missing authorization vulnerability in sensitive actions under ecrire/action/ that allows unauthenticated attackers to invoke privileged actions by supplying only a valid CSRF nonce without any server-side permission check. Attackers can bypass template-level authorization guards through direct HTTP requests to invoke actions such as editer_auteur, enabling arbitrary account p...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-72710 Newly scored	9.3	CRIT		0.006		SPIP before 4.4.18 contains a mass assignment vulnerability in the editor_objet action that allows unauthenticated attackers to write arbitrary rows to any SQL table lacking a champs_editables allowlist by supplying an attacker-controlled arg parameter resolving to internal database tables. Attackers can insert a malicious row into the spip_jobs queue with a controlled PHP function and arguments, which is then dyn...
CVE-2026-73807 New	9.3	CRIT		0.007		The mySCADA myPRO Manager command API does not properly enforce authentication for privileged functions. An unauthenticated attacker with network access to the affected API could exploit this vulnerability to access privileged management functions.
CVE-2026-73957 New	9.3	CRIT		0.003		Vulnerability in the Oracle WebCenter Portal product of Oracle Fusion Middleware (component: Portlet Services). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle WebCenter Portal. Successful attacks require human interaction from a person other than the attacker and while the vuln...
CVE-2026-81855 New	9.3	CRIT		0.005		A hardcoded cryptographic client authentication key vulnerability exists in the robot testing framework component of Wärsilä FOS-Onboard.
CVE-2026-83027 New	9.3	CRIT		0.003		Vulnerability in the Oracle Identity Manager Connector product of Oracle Fusion Middleware (component: Core). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.1.0. Easily exploitable vulnerability allows unauthenticated attacker with access to the physical communication segment attached to the hardware where the Oracle Identity Manager Connector executes to compromise Oracle Identity Manager Connec...
CVE-2026-88866 Newly scored	9.3	CRIT		0.003		WWBN AVideo through commit c3edcc274c389816d434acada07ee78eaf330c1 contains a stored cross-site scripting vulnerability in the LoginControl plugin that fails to encode the User-Agent header before storing it in login history. Attackers with any valid login account can inject malicious scripts in the User-Agent header that execute in administrator browsers when viewing the Login History page, allowing script execu...
CVE-2026-89040 New	9.3	CRIT		0.009		Tencent Mass Service Engine in Cluster (MSEC) allows a remote, unauthenticated attacker to send a crafted POST request including ../ and gain root access on the target device. An attacker who uploads a webshell can execute arbitrary code as root.
CVE-2026-89308 New	9.3	CRIT		0.03		An unauthenticated OS command injection vulnerability exists in the ping.php endpoint, allowing remote attackers to execute arbitrary commands on the underlying operating system and achieve remote code execution.
CVE-2026-91939 New	9.3	CRIT		0.006		Cotonti 1.0.0 Comments plugin passes the ci GET parameter to unserialize() without allowed_classes restriction, allowing unauthenticated attackers to instantiate arbitrary PHP classes with attacker-controlled properties. Attackers can exploit PHP object injection through crafted serialized payloads to trigger gadget chains and achieve database manipulation or code execution.
CVE-2026-91949 New	9.3	CRIT		0.004		FreeRDP server versions before 3.31.0 contain a protocol negotiation bypass vulnerability that allows unauthenticated attackers to establish RDSTLS connections despite server policy disabling them. Attackers can send incompatible protocol requests, receive negotiation failures, then complete TLS handshake and enter RDSTLS to bypass pre-authentication transport restrictions.
CVE-2026-45051 New	9.2	CRIT		0.005		Open Access Management (OpenAM) is an access management solution. Prior to 16.1.1, WebAuthnAuthentication loads a serialized AuthenticatorImpl object graph from the configured userAttribute through loadAuthenticators without an ObjectInputFilter. Exploitation requires the WebAuthn flow to be reachable and an attacker to have previously written controlled data to that attribute through delegated administration, pro...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-46495 New	9.2	CRIT		0.007		OpenDJ is an LDAPv3 compliant directory service. Prior to 5.1.1, the JMX RMI connector in opendj-server-legacy/src/main/java/org/opens/server/protocols/jmx/RmiConnector.java processes attacker-controlled credential objects before authentication without a restrictive jmx.remote.rmi.server.credentials.filter.pattern, and RmiAuthenticator.authenticate in opendj-server-legacy/src/main/java/org/opens/server/protocols...
CVE-2026-62263 New	9.2	CRIT		0.005		Open Access Management (OpenAM) is an access management solution. Prior to 16.1.2, WebAuthnAuthentication.deserialize applies an ObjectInputFilter that allows every serialized object at depth greater than 1 and therefore constrains only an AuthenticatorImpl root object. A pre-authentication attacker can supply a userHandle whose serialized graph has a valid AuthenticatorImpl root and a nested gadget class, causing...
CVE-2026-69204 New	9.2	CRIT		0.003	maven:org.http4s:http4s-ember-core_2.12, maven:org.http4s:http4s-ember-core_2.13, maven:org.http4s:http4s-ember-core_3 fixed: 0.23.35, 1.0.0-M47	Http4s is a Scala interface for HTTP services. Prior to 0.23.35 and 1.0.0-M47, Ember HTTP/1.1 does not reject messages containing both Transfer-Encoding and Content-Length, so an intermediary and Ember can select different body framing rules. When ember-server is behind a keep-alive intermediary that forwards both headers and frames by Content-Length, an unauthenticated attacker can smuggle a second request, bypas...
CVE-2026-73458 New	9.2	CRIT		0.004		On affected platforms running Arista EOS with authenticated Bidirectional Forwarding Detection (BFD) sessions configured, a specially crafted packet can cause the BFD session(s) to go down. This may result in undesirable network changes because various routing protocols monitor status on BFD session(s).
CVE-2026-88881 Newly scored	9.2	CRIT		0.003		Renovate, a dependency update tool, follows pagination links supplied by the GitHub server in the HTTP `Link` header when interacting with GitHub.com, GitHub Enterprise Cloud, or GitHub Enterprise Server, and sends the credentials configured for that host to the URL given as the 'next' page. Because the pagination URL is not validated against the host originally contacted, a malicious or compromised GitHub server ...
CVE-2026-18924 Newly scored	9.1	CRIT		0.009	haxx:curl	A flaw in libcurl's handling of HTTP/2 Server Push streams, when the parent handle is set to share connections with other handles, can lead to use-after-free in the cleanup process.
CVE-2026-46488 New	9.1	CRIT		0.003		motionEye (mEye) is an online interface for a piece of software called "motion," which is a video surveillance program with motion detection. Prior to 0.44.0, motionEye accepts the client-controlled meye_username and meye_password_hash cookies as authentication material without server-side session validation. An unauthenticated attacker who knows a target username and corresponding hash can set the cookies manuall...
CVE-2026-48717 New	9.1	CRIT		0.003		Open Access Management (OpenAM) is an access management solution. Prior to 16.1.1, AuthorizationCodeGrantTypeHandler requires a code_verifier only when the realm-wide codeVerifierEnforced setting is enabled, even when an authorization code stores a code_challenge. Because that setting is disabled by default, an attacker who intercepts a PKCE-protected authorization code can omit code_verifier and redeem the code, ...
CVE-2026-52824 New	9.1	CRIT		0.021		Kimai is an open-source time tracking application. Prior to 2.58.0, the official Docker image sets APP_SECRET to the public value change_this_to_something_unique in Dockerfile, and .docker/entrypoint.sh neither replaces nor rejects that value before Symfony uses it as kernel.secret. An unauthenticated attacker who reaches a deployment that did not override APP_SECRET, knows a username, correctly guesses the account...
CVE-2026-55158 New	9.1	CRIT		0.004		Conflibot warns in advance when merging a pull request will cause conflicts in other open pull requests. Prior to 1.2.1, src/index.ts builds git checkout, git merge, and git format-patch commands by interpolating the attacker-controlled pull request head.ref value into strings passed to exec. In the documented pull_request_target configuration, an attacker can open a pull request, including from a fork, whose bran...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-61800 Newly scored	9.1	CRIT		0.006	wazuh:wazuh	Wazuh is an open-source security platform providing unified XDR and SIEM protection for endpoints and cloud workloads. In versions 4.4.0 through 4.14.6, a party holding the cluster key can write, overwrite, or delete arbitrary files under /var/ossec on worker nodes, leading to remote code execution as root. During cluster file synchronization, the non-merged branch of update_master_files_in_worker() moves each sta...
CVE-2026-63696 New	9.1	CRIT		0.003		Dell SmartFabric OS10 Software, versions prior to 10.6.1.3, contains a Download of Code Without Integrity Check vulnerability. A high privileged attacker with remote access could potentially exploit this vulnerability, leading to Code execution.
CVE-2026-73944 New	9.1	CRIT		0.003		Vulnerability in the Oracle Access Manager product of Oracle Fusion Middleware (component: Authentication Engine). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.1.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Access Manager. Successful attacks of this vulnerability can result in unauthorized creation, deletion or modificat...
CVE-2026-73946 New	9.1	CRIT		0.003		Vulnerability in the Oracle Access Manager product of Oracle Fusion Middleware (component: Authentication Engine). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.1.0. Easily exploitable vulnerability allows high privileged attacker with network access via HTTP to compromise Oracle Access Manager. While the vulnerability is in Oracle Access Manager, attacks may significantly impact additional pro...
CVE-2026-73952 New	9.1	CRIT		0.003		Vulnerability in the Oracle WebCenter Portal product of Oracle Fusion Middleware (component: Portlet Services). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle WebCenter Portal. Successful attacks of this vulnerability can result in unauthorized creation, deletion or modificati...
CVE-2026-76675 New	9.1	CRIT		0.013		A command injection vulnerability exists in the command line interface of EdgeConnect SD-WAN Gateways. Successful exploitation could allow an authenticated remote attacker with high privileges to execute arbitrary commands on the underlying operating system leading to complete system compromise.
CVE-2026-83001 New	9.1	CRIT		0.005		Vulnerability in the Oracle Access Manager product of Oracle Fusion Middleware (component: Authentication Engine). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.1.0. Easily exploitable vulnerability allows high privileged attacker with network access via HTTP to compromise Oracle Access Manager. While the vulnerability is in Oracle Access Manager, attacks may significantly impact additional pro...
CVE-2026-83006 New	9.1	CRIT		0.005		Vulnerability in the Oracle WebCenter Enterprise Capture product of Oracle Fusion Middleware (component: Client Bundle). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows high privileged attacker with network access via HTTP to compromise Oracle WebCenter Enterprise Capture. While the vulnerability is in Oracle WebCenter Enterprise Capture, attacks may s...
CVE-2026-83064 New	9.1	CRIT		0.005		Vulnerability in the Oracle WebCenter Portal product of Oracle Fusion Middleware (component: Runtime Tools). Supported versions that are affected are 12.2.1.4.0 and 14.1.2.0.0. Easily exploitable vulnerability allows high privileged attacker with network access via HTTP to compromise Oracle WebCenter Portal. While the vulnerability is in Oracle WebCenter Portal, attacks may significantly impact additional produ...
CVE-2026-83103 New	9.1	CRIT		0.005		Vulnerability in the Oracle Forms product of Oracle Fusion Middleware (component: Forms Services, C/S, Charmode). Supported versions that are affected are 12.2.1.19.0 and 14.1.2.0.0. Easily exploitable vulnerability allows high privileged attacker with network access via HTTP to compromise Oracle Forms. While the vulnerability is in Oracle Forms, attacks may significantly impact additional products (scope chang...
CVE-2026-83104 New	9.1	CRIT		0.004		Vulnerability in the Oracle Forms product of Oracle Fusion Middleware (component: Forms Services, C/S, Charmode). Supported versions that are affected are 12.2.1.19.0 and 14.1.2.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via TCP to compromise Oracle Forms. Successful attacks of this vulnerability can result in unauthorized creation, deletion or modification access...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-83107 New	9.1	CRIT		0.005		Vulnerability in the Oracle Forms product of Oracle Fusion Middleware (component: Forms Services, C/S, Charmode). Supported versions that are affected are 12.2.1.19.0 and 14.1.2.0.0. Easily exploitable vulnerability allows high privileged attacker with network access via HTTP to compromise Oracle Forms. While the vulnerability is in Oracle Forms, attacks may significantly impact additional products (scope chang...
CVE-2026-83149 New	9.1	CRIT		0.003		Vulnerability in Oracle Application Testing Suite. The supported version that is affected is 13.3.0.1. Easily exploitable vulnerability allows low privileged attacker having Test Manager for Web Apps privilege with network access via HTTP to compromise Oracle Application Testing Suite. While the vulnerability is in Oracle Application Testing Suite, attacks may significantly impact additional products (scope cha...
CVE-2026-83154 New	9.1	CRIT		0.003		Vulnerability in the Siebel CRM End User product of Oracle Siebel CRM (component: Open UI). Supported versions that are affected are 17.0-26.7. Easily exploitable vulnerability allows unauthenticated attacker with network access via SOAP to compromise Siebel CRM End User. Successful attacks of this vulnerability can result in unauthorized creation, deletion or modification access to critical data or all Siebel ...
CVE-2026-83196 New	9.1	CRIT		0.004		Vulnerability in the Siebel CRM Deployment product of Oracle Siebel CRM (component: Server Infrastructure). Supported versions that are affected are 17.0-26.7. Easily exploitable vulnerability allows high privileged attacker with network access via HTTP to compromise Siebel CRM Deployment. While the vulnerability is in Siebel CRM Deployment, attacks may significantly impact additional products (scope change). S...
CVE-2026-83197 New	9.1	CRIT		0.004		Vulnerability in the Siebel Apps - Financial Services product of Oracle Siebel CRM (component: Financial Accounts). Supported versions that are affected are 17.0-26.7. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Siebel Apps - Financial Services. Successful attacks of this vulnerability can result in unauthorized access to critical data or complete ...
CVE-2026-83201 New	9.1	CRIT		0.003		Vulnerability in the Siebel CRM Deployment product of Oracle Siebel CRM (component: Server Infrastructure). Supported versions that are affected are 17.0-26.7. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Siebel CRM Deployment. Successful attacks of this vulnerability can result in unauthorized creation, deletion or modification access to critical d...
CVE-2026-83202 New	9.1	CRIT		0.004		Vulnerability in the Siebel CRM Deployment product of Oracle Siebel CRM (component: Server Infrastructure). Supported versions that are affected are 17.0-26.7. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Siebel CRM Deployment. Successful attacks of this vulnerability can result in unauthorized creation, deletion or modification access to critical d...
CVE-2026-83229 New	9.1	CRIT		0.004		Vulnerability in the Siebel CRM Deployment product of Oracle Siebel CRM (component: Siebel Management Console). Supported versions that are affected are 17.0-26.7. Easily exploitable vulnerability allows high privileged attacker with network access via HTTP to compromise Siebel CRM Deployment. While the vulnerability is in Siebel CRM Deployment, attacks may significantly impact additional products (scope change)...
CVE-2026-83260 New	9.1	CRIT		0.005		Vulnerability in the Oracle Agile PLM product of Oracle Supply Chain (component: Event Java PX). The supported version that is affected is 9.3.6. Easily exploitable vulnerability allows high privileged attacker with network access via T3, IIOP to compromise Oracle Agile PLM. While the vulnerability is in Oracle Agile PLM, attacks may significantly impact additional products (scope change). Successful attacks o...
CVE-2026-83268 New	9.1	CRIT		0.004		Vulnerability in the Oracle BI Publisher product of Oracle Analytics (component: BI Platform Security). Supported versions that are affected are 8.2.0.0.0, 12.2.1.4.0 and 26.01.0.0.0. Easily exploitable vulnerability allows high privileged attacker with network access via HTTP to compromise Oracle BI Publisher. While the vulnerability is in Oracle BI Publisher, attacks may significantly impact additional produc...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84961 Newly scored	9.1	CRIT		0.001	nodejs:undici	undici's BalancedPool constructor passes its entire options object through an internal deep-clone that serializes and reparses the value as JSON. Because JSON cannot represent functions, any function-valued TLS option, such as a caller-supplied checkServerIdentity callback or a custom connector inside the connect option, is silently discarded before it reaches the TLS layer. As a result a peer whose certificate th...
CVE-2026-85184 Newly scored	9.1	CRIT		0.003	fastify:fastify/middie	@fastify/middie versions >= 9.1.0 and before 9.3.4 decide whether to run path-scoped middleware by matching against the raw request target, while the Fastify router resolves an absolute-form request target to its path before dispatching. Because the two layers evaluate different strings, a request using an absolute-form target reaches the route handler while the path-scoped middleware, such as authentication or au...
CVE-2026-87128 New	9.1	CRIT		0.004		Vulnerability in the Oracle Hyperion Data Relationship Management product of Oracle Hyperion (component: Access and security). The supported version that is affected is 11.2.26.0.000. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Hyperion Data Relationship Management. Successful attacks of this vulnerability can result in unauthorized creatio...
CVE-2026-87129 New	9.1	CRIT		0.003		Vulnerability in the Oracle Hyperion Data Relationship Management product of Oracle Hyperion (component: Access and security). The supported version that is affected is 11.2.26.0.000. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Hyperion Data Relationship Management. Successful attacks of this vulnerability can result in unauthorized creatio...
CVE-2026-87170 New	9.1	CRIT		0.004		Vulnerability in the Oracle Hyperion Financial Management product of Oracle Hyperion (component: Security). The supported version that is affected is 11.2.26.0.000. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Hyperion Financial Management. Successful attacks of this vulnerability can result in unauthorized creation, deletion or modification...
CVE-2026-87173 New	9.1	CRIT		0.004		Vulnerability in the Oracle Hyperion Financial Management product of Oracle Hyperion (component: Security). The supported version that is affected is 11.2.26.0.000. Easily exploitable vulnerability allows unauthenticated attacker with network access via TCP to compromise Oracle Hyperion Financial Management. Successful attacks of this vulnerability can result in unauthorized creation, deletion or modification ...
CVE-2026-87175 New	9.1	CRIT		0.003		Vulnerability in the Oracle Hyperion Financial Management product of Oracle Hyperion (component: Security). The supported version that is affected is 11.2.26.0.000. Easily exploitable vulnerability allows unauthenticated attacker with network access via TCP to compromise Oracle Hyperion Financial Management. Successful attacks of this vulnerability can result in unauthorized creation, deletion or modification ...
CVE-2026-87176 New	9.1	CRIT		0.004		Vulnerability in the Oracle Hyperion Financial Management product of Oracle Hyperion (component: Security). The supported version that is affected is 11.2.26.0.000. Easily exploitable vulnerability allows unauthenticated attacker with network access via TCP to compromise Oracle Hyperion Financial Management. Successful attacks of this vulnerability can result in unauthorized creation, deletion or modification ...
CVE-2026-87189 New	9.1	CRIT		0.005		Vulnerability in the Oracle Hyperion Financial Management product of Oracle Hyperion (component: Security). The supported version that is affected is 11.2.26.0.000. Easily exploitable vulnerability allows high privileged attacker with network access via Oracle Net to compromise Oracle Hyperion Financial Management. While the vulnerability is in Oracle Hyperion Financial Management, attacks may significantly imp...
CVE-2026-87214 New	9.1	CRIT		0.003		Vulnerability in the Oracle Hyperion Financial Management product of Oracle Hyperion (component: Security). The supported version that is affected is 11.2.26.0.000. Easily exploitable vulnerability allows high privileged attacker with network access via HTTP to compromise Oracle Hyperion Financial Management. While the vulnerability is in Oracle Hyperion Financial Management, attacks may significantly impact ad...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-87217 New	9.1	CRIT		0.004		Vulnerability in the Oracle Hyperion Financial Management product of Oracle Hyperion (component: Security). The supported version that is affected is 11.2.26.0.000. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Hyperion Financial Management. Successful attacks of this vulnerability can result in unauthorized creation, deletion or modification...
CVE-2026-87223 New	9.1	CRIT		0.003		Vulnerability in the Oracle Hyperion Financial Management product of Oracle Hyperion (component: Security). The supported version that is affected is 11.2.26.0.000. Easily exploitable vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Hyperion Financial Management. Successful attacks of this vulnerability can result in unauthorized creation, deletion or modification...
CVE-2026-89022 New	9.1	CRIT		0.003		BookStack before 26.05.5 contains an authentication bypass vulnerability in its social login implementation that allows unauthenticated attackers to sign in as arbitrary users by authenticating through a different social provider sharing the same driver_id namespace. Attackers can authenticate at one enabled social provider using a user ID that matches an account linked to a different social provider, bypassing cr...
CVE-2026-90647 Newly scored	9.1	CRIT		0.001		ASE/Kalkitech ASE2000 V2 Communication Test Set 2.35 through 2.37 on Windows contains an improper certificate validation vulnerability in the IEC 60870-5-104 TLS client (Task Mode). This allows a network-positioned attacker to bypass certificate validation via a certificate with multiple simultaneous faults, enabling a Man-in-the-Middle attack on protected communications.
CVE-2026-90711 New	9.1	CRIT		0.002		proxy-addr is a Node.js module that determines a request's client address behind trusted reverse proxies, and it backs Express req.ip and req.ips. In versions 1.1.0 through 2.0.7, a trust subnet written in IPv4-mapped IPv6 notation with an IPv4-sized prefix, such as ::ffff:10.0.0.0/8 instead of the correct ::ffff:10.0.0.0/104, is accepted without error but trusts every IPv4 address on the internet rather than the ...
CVE-2026-91995 New	9.1	CRIT		0.006		pig before 4.1.0 contains an authentication bypass vulnerability in the /register/password endpoint where password verification results are discarded, allowing any value as the current password. Remote attackers can submit a username with an incorrect current password to overwrite any account credential including the admin account and gain full administrative control.
CVE-2024-14029 New	9.0	CRIT		0.004		Tornado before 6.4.1 ignores duplicate Transfer-Encoding: chunked headers, treating requests as having no message body and parsing the chunked body as a subsequent request. Attackers can exploit this inconsistency when Tornado is deployed behind proxies to perform HTTP request smuggling, enabling access control bypass, cache poisoning, or connection desynchronization.
CVE-2026-61549 New	9.0	CRIT		0.002		Woodpecker is a CI/CD engine. From 1.0.0 until 3.16.0, pipeline/backend/kubernetes/backend_options.go defines backend_options.kubernetes.serviceAccountName, and the Kubernetes backend in pipeline/backend/kubernetes/pod.go copies that pipeline-step value directly into the pod specification without administrator authorization. Any user with Push permission on a connected repository can therefore run pipeline pods un...
CVE-2026-77866 New	9.0	CRIT		0.005		Server-Side Request Forgery (SSRF) vulnerability in Slab safeurl allows an attacker who controls a validated URL to reach internal network destinations the library is configured to block. Only IPv4 addresses are matched against the reserved ranges and the blocklist. Every other address is treated as matching nothing, so a destination that is rejected in its IPv4 form is accepted when written as an IPv6 address, I...
CVE-2026-77972 New	9.0	CRIT		0.003		Time-of-check Time-of-use (TOCTOU) Race Condition in Slab safeurl allows an attacker who controls a hostname's DNS responses to reach internal network destinations that validation rejected. Validation returns a verdict and not the address it approved, so the HTTP clients the library ships receive the original hostname and resolve it a second time when the request is made. An attacker who controls the authoritativ...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-83105 New	9.0	CRIT		0.004		Vulnerability in the Oracle Forms product of Oracle Fusion Middleware (component: Forms Services, C/S, Charmode). Supported versions that are affected are 12.2.1.19.0 and 14.1.2.0.0. Difficult to exploit vulnerability allows unauthenticated attacker with network access via HTTP to compromise Oracle Forms. While the vulnerability is in Oracle Forms, attacks may significantly impact additional products (scope cha...
CVE-2026-91932 New	9.0	CRIT		0.008		Flowise before 3.1.4 contains a validation bypass vulnerability in MCP server configuration allowing authenticated attackers remote code execution through an unvalidated cwd parameter. Attackers can bypass path validation using clean filenames in the args array while controlling the working directory to execute malicious code.

Watchlist matches (other priorities)

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-20275 Newly scored	8.8	HIGH		0.002		As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco IOS XR Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20275 are related to incorrect calculation issues that are grouped under the Co...
CVE-2026-20278 Newly scored	8.8	HIGH		0.003		As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco IOS XR Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20278 are related to improper neutralization issues that are grouped under the ...
CVE-2026-20280 Newly scored	8.8	HIGH		0.003		As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco IOS XR Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20280 are related to improper checking or handling of exceptional conditio...
CVE-2026-44300 New	8.8	HIGH		0.004		OpenCost provides cost monitoring for Kubernetes workloads and cloud costs. Prior to 1.121.0, the POST /serviceKey endpoint in pkg/costmodel/router.go allows a network client to invoke AddServiceKey without mandatory authentication and submit an arbitrary key form value that is written to the GCP service-account key.json file returned by GetGCPAuthSecretFilePath in core/pkg/env/core.go. The attacker controls the f...
CVE-2026-67368 Newly scored	8.8	HIGH		0.007	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Improper link resolution before file access ('link following') in SQL Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-67631 Newly scored	8.8	HIGH		0.006	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-67638 Newly scored	8.8	HIGH		0.007	microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-67639 Newly scored	8.8	HIGH		0.007	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-67642 Newly scored	8.8	HIGH		0.005	microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-67643 Newly scored	8.8	HIGH		0.008	microsoft:sql_server_2022, microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-68775 Newly scored	8.8	HIGH		0.005	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-68786 Newly scored	8.8	HIGH		0.005	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-69669 Newly scored	8.8	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Kernel allows an unauthorized attacker to execute code over a network.
CVE-2026-73028 Newly scored	8.8	HIGH		0.005	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Improper access control in SQL Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-77480 Newly scored	8.8	HIGH		0.005	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Insufficient granularity of access control in SQL Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-77481 Newly scored	8.8	HIGH		0.006	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-77482 Newly scored	8.8	HIGH		0.008	microsoft:sql_server_2017, microsoft:sql_server_2019	Heap-based buffer overflow in SQL Server allows an unauthorized attacker to execute code over a network.
CVE-2026-77483 Newly scored	8.8	HIGH		0.005	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Weak authentication in SQL Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-77484 Newly scored	8.8	HIGH		0.011	microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Deserialization of untrusted data in SQL Server allows an authorized attacker to execute code over a network.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77486 Newly scored	8.8	HIGH		0.005	microsoft:sql_server_2017, microsoft:sql_server_2019	Integer overflow or wraparound in SQL Server allows an unauthorized attacker to execute code over a network.
CVE-2026-77487 Newly scored	8.8	HIGH		0.005	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Improper access control in SQL Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-78456 Newly scored	8.8	HIGH		0.009	microsoft:sql_server_2022	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-55887 New	8.7	HIGH		0.002		MCP Gateway allows easy and secure running and deployment of MCP servers. From 0.21.0 until 0.42.2, Docker MCP Gateway YAML-unmarshalled the attacker-controlled io.docker.server.metadata OCI image label into the broad catalog.Server structure for direct docker:// references and catalog snapshot imports in pkg/oci/self_contained.go and pkg/workingset/workingset.go. Runtime-shaping fields including Volumes, User, an...
CVE-2026-72708 Newly scored	8.7	HIGH		0.003		SPIP before 4.4.18 contains an unauthenticated blind SQL injection vulnerability in the SQL escaping layer that allows unauthenticated attackers to inject arbitrary SQL by supplying a crafted annee parameter value matching a word character followed by an open parenthesis, which bypasses escaping for date-type columns across MySQL, SQLite, and PostgreSQL backends. Attackers can exploit the always-present sitemap.xml...
CVE-2026-79994 New	8.7	HIGH		0.001		The guest-to-host Unix-domain socket relay in Docker Sandboxes validates that a socket path is inside an authorized workspace, but later reconnects using the pathname. A malicious guest can replace an intermediate directory with a symlink between validation and connection, causing the host to connect to an arbitrary AF_UNIX socket outside the shared workspace. This can expose data or host-side capabilities provide...
CVE-2026-91937 New	8.7	HIGH		0.003		Flowise before 3.1.4 fails to sanitize the overrideConfig.sessionId parameter before using it in MongoDB queries within the MongoDBMemory node. Unauthenticated attackers can submit MongoDB operator objects through the prediction API to read chat history records belonging to other users from the shared collection.
CVE-2026-20276 Newly scored	8.6	HIGH		0.003		As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco IOS XR Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20276 are related to insufficient control flow management issues that are group...
CVE-2026-67636 Newly scored	8.5	HIGH		0.005	microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Out-of-bounds read in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-88765 New	8.5	HIGH		0.007		GitLab has remediated an issue in GitLab EE affecting all versions from 12.3 to 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 under certain conditions could allow an authenticated user to achieve remote code execution by importing a specially crafted Git project export to overflow the Unicode conversion buffer used in Advanced Search indexing.
CVE-2026-88886 Newly scored	8.5	HIGH		0.002		Renovate is a dependency update automation tool. In versions before 44.14.7 (and in Mend Renovate CE/EE distributions before 15.4.0, and the mend-renovate-enterprise-edition Helm chart before 10.4.0), the manager/gradle-wrapper module does not escape the distributionUrl value read from a repository's gradle/wrapper/gradle-wrapper.properties file before invoking the Gradle Wrapper CLI. In self-hosted deployments co...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-69638 Newly scored	8.4	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an unauthorized attacker to execute code locally.
CVE-2026-20277 Newly scored	8.2	HIGH		0.002		As part of Cisco's ongoing commitment to proactive security and product quality, the Cisco IOS XR Software engineering team has conducted a comprehensive internal security review. This review resulted in a software hardening releases that address multiple internally discovered vulnerabilities. The vulnerabilities tracked by CVE-2026-20277 are related to protection mechanism failure issues that are grouped under...
CVE-2026-69846 Newly scored	8.2	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Integer overflow or wraparound in Windows Secure Kernel Mode allows an authorized attacker to elevate privileges locally.
CVE-2026-69906 Newly scored	8.2	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Secure Kernel Mode allows an authorized attacker to elevate privileges locally.
CVE-2026-9327 Newly scored	8.1	HIGH		0.002	ibm:websphere_application_server	IBM WebSphere Application Server 9.0, and 8.5 could allow an authenticated user with a low-privilege administrative role to modify security configuration. This could result in information disclosure or denial of service.
CVE-2026-55225 New	8.0	HIGH		0.002		Strimzi provides a way to run an Apache Kafka cluster on Kubernetes or OpenShift in various deployment configurations. In Strimzi 1.0.0 and earlier, an attacker who can create a Kafka custom resource can set Kafka.spec.entityOperator watchedNamespace to a target namespace, causing the Cluster Operator to create a Role with full Secret CRUD permissions there and bind it to the Entity Operator ServiceAccount in the ...
CVE-2026-69875 Newly scored	8.0	HIGH		0.008	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an authorized attacker to elevate privileges over a network.
CVE-2026-68787 Newly scored	7.8	HIGH		0.002	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code locally.
CVE-2026-69709 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an authorized attacker to execute code locally.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-70289 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Win32 Kernel Subsystem allows an authorized attacker to elevate privileges locally.
CVE-2026-71337 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:wi	Stack-based buffer overflow in Windows Storage Management Provider allows an authorized attacker to elevate privileges locally.
CVE-2026-71343 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Remote Access Connection Manager allows an authorized attacker to execute code locally.
CVE-2026-83978 Newly scored	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-13210 New	7.7	HIGH		0.004		GitLab has remediated an issue in GitLab CE/EE affecting all versions from 15.7 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that under certain conditions could have allowed an authenticated user to access CI/CD variables outside their intended environment scope due to improper input validation in the environment scope pattern matcher.
CVE-2026-55149 New	7.5	HIGH		0.004		Vouch Proxy is an SSO and OAuth/OIDC login solution for Nginx using the auth_request module. Prior to 0.48.0, Cookie in pkg/cookie/cookie.go parses the total part count from an attacker-controlled multipart cookie name and passes the value to make([]string, numParts) without checking that the value is positive or reasonably bounded. Requests to /validate and /_external-auth:id reach JWTCacheHandler in pkg/jwtmana...
CVE-2026-70587 Newly scored	7.5	HIGH		0.008	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Improper null termination in Windows Remote Desktop Protocol allows an unauthorized attacker to disclose information over a network.
CVE-2026-75092 New	7.3	HIGH		0.001		A privilege escalation flaw was found in the scan_mysql actor of leapp-upgrade-el9toel10 (provided by leapp-repository). During RHEL 9 to RHEL 10 upgrades, the actor runs: mysqld --validate-config --log-error-verbosity=2 directly as root in the Leapp actor context, bypassing the packaged MySQL systemd unit that normally starts the daemon as User=mysql. A process compromised as the mysql OS identity can write a ve...
CVE-2026-21586 New	7.1	HIGH		0.003		This High severity Improper Authorization vulnerability was introduced in versions 7.4.0, 7.13.0, 8.5.0, 8.9.0, 9.0.1, 9.1.0, 9.2.0, 9.3.1, 9.4.0, 9.5.1, 10.0.2, 10.1.0, and 10.2.0 of Confluence Data Center. This Improper Authorization vulnerability, with a CVSS Score of 7.1, allows an authenticated attacker to gain unintended access and can lead to the exposure of resources or functionality, possibly providing...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-21587 New	7.1	HIGH		0.003		This High severity Improper Authorization vulnerability was introduced in version 11.3.0 of Jira Service Management Data Center. This Improper Authorization vulnerability, with a CVSS Score of 7.1, allows an authenticated attacker to gain unintended access and can lead to the exposure of resources or functionality, possibly providing attackers with sensitive information or even execute arbitrary code. Atla...
CVE-2026-21588 New	7.1	HIGH		0.003		This High severity DoS (Denial of Service) vulnerability was introduced in versions 8.9.0, 9.0.1, 9.1.0, 9.2.0, 9.3.1, 9.4.0, 9.5.1, 10.0.2, 10.1.0, and 10.2.0 of Confluence Data Center. This DoS (Denial of Service) vulnerability, with a CVSS Score of 7.1, allows an authenticated attacker to cause a resource to be unavailable for its intended users by temporarily or indefinitely disrupting services of a host co...
CVE-2026-9176 Newly scored	7.1	HIGH		0.001	ibm:websphere_application_server	IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to a security bypass due to improper authentication controls. A local attacker could exploit this vulnerability to escalate privileges and gain unauthorized access to protected resources.
CVE-2026-71340 Newly scored	7.0	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows File History Service allows an authorized attacker to elevate privileges locally.
CVE-2026-71342 Newly scored	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Remote Access Connection Manager allows an authorized attacker to elevate privileges locally.
CVE-2026-77485 Newly scored	7.0	HIGH		0.002	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Use after free in SQL Server allows an authorized attacker to elevate privileges locally.
CVE-2026-83231 New	7.0	HIGH		0.002		Vulnerability in the Helidon product of Oracle Fusion Middleware (component: helidon-dbclient-mongodb). Supported versions that are affected are 3.0.0-3.2.20 and 4.0.0-4.5.4. Difficult to exploit vulnerability allows unauthenticated attacker with network access via HTTP to compromise Helidon. Successful attacks of this vulnerability can result in unauthorized access to critical data or complete access to all He...
CVE-2026-53941 New	6.9	MEDI		0.004		Inspektor Gadget is a set of tools and framework for data collection and system inspection on Kubernetes clusters and Linux hosts using eBPF. From 0.27.0 until 0.53.1, the uprobe library resolver can allow an unprivileged container to consume excessive CPU and block other containers from starting by supplying a crafted /etc/ld.so.cache file while an uprobe-based gadget is active. The parser in pkg/uprotracer/ldc...
CVE-2026-89263 Newly scored	6.9	MEDI		0.003		MoguBlog through 6.2 fails to authenticate requests to the /web/comment/closeEmailNotification endpoint, allowing unauthenticated attackers to disable email notifications for arbitrary users. Remote callers can modify the startEmailNotification flag in Redis cache for any user identifier to suppress reply notifications without authorization.
CVE-2026-90439 New	6.9	MEDI		0.003		NGINX Plus and NGINX Open Source have a vulnerability in the ngx_http_v3_module module. When using HTTP/3 with OpenSSL versions <= OpenSSL 3.5.0 under certain configurations, a limited heap buffer overflow could happen while processing a TLS handshake. This can happen in a non-deterministic manner that is beyond the attacker's control. This may cause a heap buffer overflow in the NGINX worker process leading to a ...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-71329 Newly scored	6.8	MEDI		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an unauthorized attacker to execute code with a physical attack.
CVE-2026-71348 Newly scored	6.8	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Spaceport.sys allows an unauthorized attacker to execute code with a physical attack.
CVE-2026-91936 New	6.8	MEDI		0.003		Flowise versions before 3.1.4 contain a script injection vulnerability in Docker image build workflows where workflow_dispatch inputs are directly interpolated into shell run blocks. Attackers with repository write access can inject shell metacharacters through inputs like tag_version and node_version to execute arbitrary commands and steal AWS credentials and Docker Hub tokens.
CVE-2026-71339 Newly scored	6.7	MEDI		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Installer allows an authorized attacker to elevate privileges locally.
CVE-2026-67389 Newly scored	6.5	MEDI		0.007	microsoft:sql_server_2022, microsoft:sql_server_2025	Out-of-bounds read in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-67390 Newly scored	6.5	MEDI		0.01	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Buffer over-read in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-67393 Newly scored	6.5	MEDI		0.007	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Buffer over-read in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-67641 Newly scored	6.5	MEDI		0.006	microsoft:sql_server_2022, microsoft:sql_server_2025	Integer overflow or wraparound in SQL Server allows an authorized attacker to deny service over a network.
CVE-2026-67645 Newly scored	6.5	MEDI		0.006	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Out-of-bounds read in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-67648 Newly scored	6.5	MEDI		0.006	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Use of uninitialized resource in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-68776 Newly scored	6.5	MEDI		0.006	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Use of uninitialized resource in SQL Server allows an authorized attacker to disclose information over a network.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-68777 Newly scored	6.5	MEDI		0.007	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Out-of-bounds read in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-68778 Newly scored	6.5	MEDI		0.007	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Out-of-bounds read in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-68779 Newly scored	6.5	MEDI		0.006	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Out-of-bounds read in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-68780 Newly scored	6.5	MEDI		0.007	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Out-of-bounds read in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-68781 Newly scored	6.5	MEDI		0.007	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Out-of-bounds read in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-68784 Newly scored	6.5	MEDI		0.007	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Out-of-bounds read in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-73029 Newly scored	6.5	MEDI		0.007	microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Buffer over-read in SQL Server allows an authorized attacker to disclose information over a network.
CVE-2026-71338 Newly scored	6.4	MEDI		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Double free in Windows Failover Cluster allows an authorized attacker to elevate privileges locally.
CVE-2026-52724 New	5.8	MEDI		0.002		Kuma is a modern Envoy-based service mesh that can run on every cloud across both Kubernetes and VMs. Prior to 2.7.26, 2.9.16, 2.11.14, 2.12.11, and 2.13.7, Universal mode kuma-dp connections to an HTTPS control plane disable TLS peer verification when --ca-cert-file is not supplied and KUMA_CONTROL_PLANE_CA_CERT is unset. The dataplane authentication token is sent over the unverified connection, allowing an on-pa...
CVE-2026-55636 New	5.7	MEDI		0.003		Capsule is a multi-tenancy and policy-based framework for Kubernetes. From 0.13.0 until 0.13.6, charts/capsule/templates/configuration.yaml configures the validating webhook with namespace/finalize instead of the Kubernetes resource name namespaces/finalize. A user with namespaces/finalize RBAC can send a PUT request to /api/v1/namespaces/{namespace}/finalize, and the singular rule never matches the plural resourc...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-69723 Newly scored	5.7	MEDI		0.01	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Exposure of sensitive system information to an unauthorized control sphere in Windows Kernel allows an authorized attacker to disclose information over a network.
CVE-2026-50166 New	5.5	MEDI		0.002		Kuma is a modern Envoy-based service mesh that can run on every cloud across both Kubernetes and VMs. Prior to 2.7.26, 2.9.16, 2.11.14, 2.12.11, and 2.13.7, a kumactl profile manually configured for an HTTPS control plane without --ca-cert-file disables TLS peer verification and sends API tokens over the unverified connection. An attacker on the network path can intercept user or administrator API tokens and act a...
CVE-2026-69616 Newly scored	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows Remote Desktop Services allows an authorized attacker to disclose information locally.
CVE-2026-69627 Newly scored	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows Remote Desktop Licensing Service allows an authorized attacker to disclose information locally.
CVE-2026-70290 Newly scored	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use of uninitialized resource in Windows Win32 Kernel Subsystem allows an authorized attacker to disclose information locally.
CVE-2026-71341 Newly scored	5.5	MEDI		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows Partition Management Driver allows an authorized attacker to disclose information locally.
CVE-2026-77488 Newly scored	5.5	MEDI		0.003	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Integer underflow (wrap or wraparound) in SQL Server allows an authorized attacker to disclose information locally.
CVE-2026-12910 New	5.4	MEDI		0.003		GitLab has remediated an issue in GitLab CE/EE affecting all versions from 18.6 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that under certain conditions could have allowed an authenticated user to bypass SAML SSO sign-in restrictions and authenticate without SSO due to missing authentication enforcement checks.
CVE-2026-55226 New	5.4	MEDI		0.002		Strimzi provides a way to run an Apache Kafka cluster on Kubernetes or OpenShift in various deployment configurations. In Strimzi 1.0.0 and earlier, deploying only the Topic Operator or only the User Operator through the Kafka custom resource leaves the Entity Operator ServiceAccount with RBAC permissions for both components. The excess permissions can allow access to KafkaUser custom resources and Secrets when th...

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-91942 New	5.4	MEDI		0.002		crawl4ai before 0.9.3 contains a DOM-based cross-site scripting vulnerability in the Docker Playground UI that assigns untrusted crawl results to element.innerHTML. Attackers can craft malicious PDFs with event-handler markup to execute JavaScript in the Playground origin and steal API tokens from sessionStorage for authenticated API abuse.
CVE-2026-82837 New	5.3	MEDI		0.004		GitLab has remediated an issue in GitLab CE/EE affecting all versions from 10.1.0 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that certain conditions could have allowed an authenticated user to access sensitive credentials and tokens without transiting the expected proxy due to improper authorization checks on internal data emission endpoints.
CVE-2026-90848 New	5.3	MEDI		0.003		A weakness has been identified in Governikus AusweisApp up to 2.5.4. Affected is an unknown function of the component StartPAOSResponse Handler. Executing a manipulation of the argument ResultMessage can lead to cross site scripting. The attack can be launched remotely. Upgrading to version 2.5.5 is able to address this issue. It is recommended to upgrade the affected component. This CVE was requested by the vendor.
CVE-2026-91851 New	5.3	MEDI		0.003		Affected versions of MISP incorrectly filter dashboard templates that are restricted to a specific permission flag. DashboardsController::listTemplates() allowed a template when either: - its restrict_to_permission_flag matched one of the current user's permission flags, or - restrict_to_permission_flag equaled integer 0 However, restrict_to_permission_flag is a varchar. MySQL therefore performed num...
CVE-2026-91857 New	5.3	MEDI		0.002		Affected versions of MISP expose several state-changing controller actions without restricting them to POST. The affected actions are: - EventReportsController::purgeUnusedPictures() - NoticelistsController::enableNoticelist() - ServersController::removeOrphanedCorrelations() - WorkflowsController::rebuildRedis() The patch adds allowMethod(['post']) to each action, preventing them from being trig...
CVE-2026-91997 New	5.3	MEDI		0.003		evolution-api through 2.3.7 contains an incorrect array comparison in the metricsIPWhitelist middleware that always evaluates to false, allowing unauthenticated access to the /metrics endpoint. Attackers can bypass IP whitelist restrictions to access sensitive metrics disclosing server version, database client name, configured server URL, and WhatsApp instance details.
CVE-2026-9667 Newly scored	5.3	MEDI		0.003	ibm:websphere_application_server	IBM WebSphere Application Server 9.0, and 8.5 is vulnerable to server-side request forgery (SSRF) that could allow a remote, unauthenticated attacker to cause the server to send outbound requests to arbitrary endpoints.
CVE-2026-92002 New	5.1	MEDI		0.004		Affected versions of MISP use Redis to throttle repeated authentication-failure log entries. The intent is to avoid excessive duplicate logs while still recording failed authentication activity. However, User->setupRedis() returns false when Redis cannot be reached. The vulnerable _shouldLog() logic only returned true when a Redis instance existed and no throttle key was present. Therefore, when Redis was unavail...
CVE-2026-68785 Newly scored	4.9	MEDI		0.008	microsoft:sql_server_2017, microsoft:sql_server_2019, microsoft:sql_server_2022, microsoft:sql_server_2025	Heap-based buffer overflow in SQL Server allows an authorized attacker to execute code over a network.
CVE-2026-55650 New	4.4	MEDI		0.001		Outerbase Studio is a lightweight browser-based database GUI supporting PostgreSQL, MySQL, and SQLite. In version 0.10.2 and earlier, TextComponent in src/components/chart/index.tsx renders unsanitized Text Widget content through dangerouslySetInnerHTML, allowing injected markup with script-capable event handlers to execute when the widget is displayed. Outerbase Cloud and its backend services were discontinued in...
CVE-2026-84655 Newly scored	4.3	MEDI		0.002	jenkins:jenkins	Jenkins 2.579 and earlier, LTS 2.568.2 and earlier does not escape map keys when serializing objects as JSON and Python through its REST API, allowing attackers able to control map property names to inject arbitrary fields into JSON and Python API responses.

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84656 Newly scored	4.3	MEDI		0.002	jenkins:jenkins	A missing permission check in Jenkins 2.579 and earlier, LTS 2.568.2 and earlier allows attackers with Item/Read permission on at least one job to read build parameter names and values of jobs they have no access to.
CVE-2026-59341 New	4.2	MEDI		0.003		A security vulnerability exists in the Sealed Secrets controller's unauthenticated POST endpoints. By submitting a modified payload containing custom Go template logic in spec.template.data, an attacker with internal network access can abuse the handler as a decryption oracle to recover the full plaintext of any sealed secret. The POST /v1/verify and /v1/rotate handlers call Unseal() to decrypt target secrets, ...
CVE-2026-84657 Newly scored	4.2	MEDI		0.002	jenkins:jenkins	In Jenkins 2.579 and earlier, LTS 2.568.2 and earlier, the build CLI command does not check the Item/Cancel permission when using the -s flag to cancel a build triggered to wait for completion, allowing attackers with Item/Build permission to cancel builds started by other users.
CVE-2026-84653 Newly scored	3.5	LOW		0.002	jenkins:jenkins	Jenkins 2.421 through 2.579 (both inclusive), LTS 2.426.1 through 2.568.2 (both inclusive) does not correctly perform permission checks in the Appearance configuration page, allowing attackers with Overall/Manage permission to modify Appearance configuration options they should not have access to.
CVE-2026-44778 New	2.9	LOW		0.005		Inspektor Gadget is a set of tools and framework for data collection and system inspection on Kubernetes clusters and Linux hosts using eBPF. From 0.28.0 until 0.53.1, the USDT note parser in pkg/uprobttracer/usdt.go can allow an unprivileged container to crash or exhaust the memory of the privileged Inspektor Gadget process when a custom gadget containing a SEC("usdt/...") eBPF section attaches to a crafted ELF b...
CVE-2026-63020 Newly scored	2.3	LOW		0.002	f5:big-ip_access_policy_manager, f5:big-ip_advanced_firewall_manage r, f5:big-ip_advanced_web_applicati on_firewall, f5:bi	A vulnerability exists in an undisclosed BIG-IP Configuration utility page that may allow an attacker to spoof error messages Impact: An attacker may trick authenticated BIG-IP users into accessing malicious links and reflect a spoofed error message in the victim's BIG-IP Configuration utility web browser session. This is a control plane issue; there is no data plane exposure. Note: Software versio...
CVE-2026-90595 Newly scored	2.1	LOW		0.002		A security flaw has been discovered in wxiaoqi Spring-Cloud-Platform 1.0/2.2/3.0. This issue affects the function OnlineController.getOnlineInfo of the file aceModules/ace-admin/auth/controller/OnlineController.java. The manipulation results in missing authorization. The attack can be executed remotely. The exploit has been released to the public and may be used for attacks. The project was informed of the problem...
CVE-2026-91842 New	1.2	LOW		0.004		A vulnerability has been found in OpenBankProject OBP-API up to 1.10.1. This impacts the function Kryolnjection.invert of the file obp-api/src/main/scala/code/api/cache/Redis.scala of the component Kryoln Handler. Such manipulation leads to deserialization. The attack can be launched remotely. A high complexity level is associated with this attack. The exploitability is said to be difficult. The exploit has been dis...
CVE-2025-67505 Updated				0.002	maven:com.okta.sdk:okta-sdk-root fixed: 20.0.1	#### Description In the Okta Java SDK, race conditions may arise from concurrent requests using the ApiClient class. This could cause a status code or response header from one request's response to influence another request's response. #### Affected product and versions You may be affected if you meet the following preconditions: - Using the Okta Java SDK between versions 11.0.0 and 20.0.0, and - Implementing a mu...
CVE-2026-55630 New	0.0	NONE		0.003		Kiwi TCMS is an open source test management system. Prior to 16.1, TestCase.extra_link and TestPlan.extra_link accepted unsanitized user input and rendered stored values verbatim, creating an opportunity for cross-site scripting. Official Docker images and unmodified Kiwi TCMS middleware send a Content-Security-Policy header that blocks inline JavaScript, making exploitation difficult in default deployments, while...
CVE-2026-88620 New				0.002		SmartAdmin API Java17 SpringBoot3 version 3.30.0 contains an improper authorization vulnerability in the /employee/queryAll endpoint. The endpoint does not enforce the required function-level permission or data-scope authorization, allowing an authenticated low-privileged employee to retrieve employee records belonging to other departments and users

ID	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90971 New				0.001		Server-Side Request Forgery (SSRF) in the VMware synchronization feature in Devolutions Server 2026.2.16 and earlier allows a low-privileged authenticated user to obtain other users' credentials and reach internal or cloud-metadata network endpoints via a crafted connection definition submitted for datacenter discovery.
GHSA-5648-rgj9-v224 Updated		HIGH			<code>npm:@zereight/mcp-gitlab</code> fixed: 2.1.30	### Summary @zereight/mcp-gitlab exposes GitLab to an LLM agent while relying on read-only mode, a project allow-list, and transport auth as its safety controls. Five defects defeat those controls. Under the MCP threat model, tool-call arguments/content can be shaped by untrusted input (prompt injection) or a malicious client. Reviewed commit: 60adcc0de5b0e96c4c2029f7a25d2775946421d8 (package version 2.1.28). Sou...

P3/P4 items (1564) are in the Excel report. Unscored CVEs are newly published and awaiting NVD analysis; re-check tomorrow's report.